

Thanks for adding the Project! Please fill out the rest of the information to get the Badge.

Edit Project Badge Status

Projects that follow the best practices below can voluntarily self-certify and show that they've achieved an Open Source Security Foundation (OpenSSF) best practices badge.

Please 'submit' often to save your work (you can always go back and edit more later).

If you need help, have a question, or see a problem, please *file an issue* (<https://github.com/ossf/best-practices-badge/issues>).

These are the Baseline Level 1 criteria. These are criteria version v2026.02.19.

Baseline Series: [Baseline Level 1 \(/en/projects/13597/baseline-1/edit\)](/en/projects/13597/baseline-1/edit)

[Baseline Level 2 \(/en/projects/13597/baseline-2/edit\)](/en/projects/13597/baseline-2/edit)

[Baseline Level 3 \(/en/projects/13597/baseline-3/edit\)](/en/projects/13597/baseline-3/edit)

^ Basics

General

 **What is the human-readable name of the project?**

sieve-action

 **What is a brief description of the project?**

AI-powered security scanner for pull requests — finds real vulnerabilities, suppresses noise.

What language is used for this badge entry's description and justifications?

English (en)



What is the URL for the project (as a whole)?

<https://github.com/fedora-io/sieve-action>

What is the URL for the version control repository (it may be the same as the project URL)?

<https://github.com/fedora-io/sieve-action>

What license(s) is the project released under?

FLOSS License



What programming language(s) are used to implement the project?

Python, Dockerfile

What is the Common Platform Enumeration (CPE) (<https://nvd.nist.gov/cpe.cfm>) name for the project (if it has one)?

(Optional) CPE name

Other general comments about the project:

Additional Comments (in markdown)



By submitting this data about the project you agree to release it under at least the Community Data License Agreement – Permissive, Version 2.0 (<https://cdla.dev/permissive-2-0/>). This means that a Data Recipient may share the Data, with or without modifications, so long as the Data Recipient makes available the text of this agreement with the shared Data. This agreement does *not* impose any restriction or obligations with respect to the use, modification, or sharing of Results. You retain copyright (if any), and the project license is unaffected.

You can use tools and AI systems to propose changes via a simple URL, such as https://www.bestpractices.dev/en/projects/13597/choose/edit?osps_ac_01_01_status=Met&osps_ac_01_01_justification=GitHub+enforced. See our automation proposals system (<https://github.com/ossf/best-practices-badge/blob/main/docs/automation-proposals.md>) for how to do that.

Save (and continue)

Submit (and exit)

^ Controls

10/24 •

Controls



- ☒ Met
- ☐ Unmet
- ☐ N/A
- ☐ ?

When a user attempts to read or modify a sensitive resource in the project's authoritative repository, the system **MUST** require the user to complete a multi-factor authentication process. [OSPS-AC-01.01]

GitHub requires 2FA as of March 2023.



- ☐ Met
- ☐ Unmet
- ☐ N/A
- ☒ ?

When a new collaborator is added, the version control system **MUST** require manual permission assignment, or restrict the collaborator permissions to the lowest available privileges by default. [OSPS-AC-02.01]



- ☐ Met
- ☐ Unmet
- ☐ N/A
- ☒ ?

When a direct commit is attempted on the project's primary branch, an enforcement mechanism **MUST** prevent the change from being applied. [OSPS-AC-03.01]



- ☐ Met
- ☐ Unmet
- ☐ N/A
- ☒ ?

When an attempt is made to delete the project's primary branch, the version control system **MUST** treat this as a sensitive activity and require explicit confirmation of intent. [OSPS-AC-03.02]



- ☐ Met
- ☐ Unmet
- ☐ N/A
- ☒ ?

When a CI/CD pipeline operates on untrusted metadata, those parameters **MUST** be sanitized and validated prior to use in the pipeline. [OSPS-BR-01.01]



- ☐ Met
- ☐ Unmet
- ☐ N/A
- ☒ ?

When a CI/CD pipeline operates on untrusted code snapshots, it **MUST** prevent access to privileged CI/CD credentials and assets. [OSPS-BR-01.03]



- ☒ Met
- ☐ Unmet
- ☐ N/A
- ☐ ?

When the project lists a URI as an official project channel, that URI **MUST** be exclusively delivered using encrypted channels. [OSPS-BR-03.01]

Project URLs use HTTPS exclusively.



- ☒ Met
- ☐ Unmet
- ☐ N/A
- ☐ ?

When the project lists a URI as an official distribution channel, that channel **MUST** be protected from adversary-in-the-middle attacks using cryptographically authenticated channels. [OSPS-BR-03.02]

Distribution channels use HTTPS exclusively.



- ☐ Met
- ☐ Unmet
- ☐ N/A
- ☒ ?

The project **MUST** prevent the unintentional storage of unencrypted sensitive data, such as secrets and credentials, in the version control system. [OSPS-BR-07.01]



- ☐ Met
- ☒ Unmet
- ☐ N/A
- ☐ ?

When the project has made a release, the project documentation **MUST** include user guides for all basic functionality. [OSPS-DO-01.01]

No appropriate folder found for documentation basics. [documentation_basics]



- ☒ Met
- ☐ Unmet
- ☐ N/A
- ☐ ?

When the project has made a release, the project documentation **MUST** include a guide for reporting defects. [OSPS-DO-02.01]

Non-trivial SECURITY[.md] file found file in repository: <<https://github.com/fedora-io/sieve-action/blob/main/SECURITY.md>>.



- ☒ Met
☐ Unmet
☐ N/A
☐ ?

While active, the project **MUST** have one or more mechanisms for public discussions about proposed changes and usage obstacles. [OSPS-GV-02.01]

GitHub supports public discussions on proposed changes (via pull requests) and usage obstacles (via issues).



- ☒ Met
☐ Unmet
☐ N/A
☐ ?

While active, the project documentation **MUST** include an explanation of the contribution process. [OSPS-GV-03.01]

Contribution process documented in repository.



- ☐ Met
☐ Unmet
☐ N/A
☒ ?

While active, the license for the source code **MUST** meet the OSI Open Source Definition or the FSF Free Software Definition. [OSPS-LE-02.01]



- ☐ Met
- ☐ Unmet
- ☐ N/A
- ☒ ?

While active, the license for the released software assets **MUST** meet the OSI Open Source Definition or the FSF Free Software Definition. [OSPS-LE-02.02]



- ☒ Met
- ☐ Unmet
- ☐ N/A
- ☐ ?

While active, the license for the source code **MUST** be maintained in the corresponding repository's **LICENSE** file, **COPYING** file, or **LICENSE/** directory. [OSPS-LE-03.01]

License file found in repository.



- ☒ Met
- ☐ Unmet
- ☐ N/A
- ☐ ?

While active, the license for the released software assets **MUST** be included in the released source code, or in a **LICENSE** file, **COPYING** file, or **LICENSE/** directory alongside the corresponding release assets. [OSPS-LE-03.02]

Non-trivial license location file in repository: <<https://github.com/fedora-io/sieve-action/blob/main/LICENSE>>. [license_location]



- ☒ Met
- ☐ Unmet
- ☐ N/A

☐ ?

While active, the project's source code repository **MUST** be publicly readable at a static URL. [OSPS-QA-01.01]

Repository is publicly available on GitHub.



- ☒ Met
☐ Unmet
☐ N/A
☐ ?

The version control system **MUST** contain a publicly readable record of all changes made, who made the changes, and when the changes were made. [OSPS-QA-01.02]

Repository git metadata is publicly available on GitHub.



- ☐ Met
☐ Unmet
☐ N/A
☒ ?

When the package management system supports it, the source code repository **MUST** contain a dependency list that accounts for the direct language dependencies. [OSPS-QA-02.01]



- ☐ Met
☐ Unmet
☐ N/A
☒ ?

Projects with multiple repositories **MUST** document a list of codebases that are part of the project. [OSPS-QA-04.01]



- ☐ Met
- ☐ Unmet
- ☐ N/A
- ☒ ?

While active, the version control system **MUST NOT** contain generated executable artifacts.
[OSPS-QA-05.01]



- ☐ Met
- ☐ Unmet
- ☐ N/A
- ☒ ?

While active, the version control system **MUST NOT** contain unreviewable binary artifacts.
[OSPS-QA-05.02]



- ☐ Met
- ☐ Unmet
- ☐ N/A
- ☒ ?

While active, the project documentation **MUST** contain security contacts. [OSPS-VM-02.01]

By submitting this data about the project you agree to release it under at least the Community Data License Agreement – Permissive, Version 2.0 (<https://cdla.dev/permissive-2-0/>). This means that a Data Recipient may share the Data, with or without modifications, so long as the Data Recipient makes available the text of this agreement with the shared Data. This agreement does *not* impose any restriction or obligations with respect to the use, modification, or sharing of Results. You retain copyright (if any), and the project license is unaffected.

You can use tools and AI systems to propose changes via a simple URL, such as https://www.bestpractices.dev/en/projects/13597/choose/edit?osps_ac_01_01_status=Met&osps_ac_01_01_justification=GitHub+enforced. See our automation proposals system (<https://github.com/ossf/best-practices-badge/blob/main/docs/automation-proposals.md>) for how to do that.

Submit (and exit)

By submitting this data about the project you agree to release it under at least the Community Data License Agreement – Permissive, Version 2.0 (<https://cdla.dev/permissive-2-0/>). This means that a Data Recipient may share the Data, with or without modifications, so long as the Data Recipient makes available the text of this agreement with the shared Data. This agreement does *not* impose any restriction or obligations with respect to the use, modification, or sharing of Results. You retain copyright (if any), and the project license is unaffected.

You can use tools and AI systems to propose changes via a simple URL, such as https://www.bestpractices.dev/en/projects/13597/choose/edit?osps_ac_01_01_status=Met&osps_ac_01_01_justification=GitHub+enforced. See our automation proposals system (<https://github.com/ossf/best-practices-badge/blob/main/docs/automation-proposals.md>) for how to do that.

Save (and continue) 🍪

Submit (and exit)

Need help? Have a question? See a problem? Please *file an issue* (<https://github.com/ossf/best-practices-badge/issues>). Copyright © OpenSSF Best Practices Badge a Series of LF Projects, LLC (<https://www.bestpractices.dev>). For web site terms of use, trademark policy and other project policies please see these policies (<https://lfprojects.org>). For more information, see the websites of the Open Source Security Foundation (OpenSSF) (<https://openssf.org>) and The Linux Foundation (<https://www.linuxfoundation.org/>). All Rights Reserved. Please see our privacy policy (<https://www.linuxfoundation.org/privacy>).

(<https://openssf.org/>)



(<https://www.linuxfoundation.org/>)

fastly (<https://www.fastly.com/>)